

Lab 13. Windows Firewall and IPsec

IT Infrastructure Management (W04IST-SI0826G)

Wojciech Thomas

Spring 2026

1 Learning objectives

After completing this lab you will be able to:

1. Deploy an Enterprise Root CA on Windows Server 2025 using a PowerShell script.
2. Create a Windows Firewall inbound rule and deploy it domain-wide using Group Policy.
3. Capture unencrypted HTTP credentials in Wireshark and explain the risk of clear-text protocols.
4. Diagnose a silently failing IPsec configuration by inspecting the certificate's Enhanced Key Usage extension.
5. Configure an IPsec Connection Security Rule using certificate-based IKEv2 authentication.
6. Verify that IPsec encrypts network traffic by comparing Wireshark captures before and after.

2 Scenario

You have joined the security team at Contoso Ltd. A recent internal audit flagged two findings: domain servers have no consistent firewall policy, and the internal CA Web Enrollment interface transmits administrator credentials in cleartext over HTTP. Your manager has given you one lab session to demonstrate the live threat, build the PKI infrastructure needed to fix it, enforce the firewall policy via Group Policy, and encrypt the vulnerable channel with IPsec — the same sequence used in a real server hardening engagement.

3 Before you start

- You are logged in to **DC1** as **contoso\administrator**.
- **CL1** (Windows 11, domain member) is accessible and you can log in as **contoso\administrator**.
- Both machines have network connectivity to each other.
- **CL1** has access to the Internet for downloading Wireshark.

- No Certificate Authority is installed on DC1.

4 Exercise 1. Deploy Enterprise Root CA

4.1 Why this matters

The Certificate Authority you deploy in this exercise is the trust anchor for everything that follows. Installing the CA also activates the **CA Web Enrollment** service (**certsrv**) — an IIS application that transmits credentials over plain HTTP, which is exactly the vulnerable channel you will capture in Exercise 3 and encrypt in Exercise 4. Without a working CA, neither the Wireshark demonstration nor the IPsec fix is possible. In a real deployment, the CA is the first component that must be in place before any certificate-based security control can be configured — getting it right before anything else is not optional.

4.2 Task 1 — Run the CA installation script on DC1

A PowerShell script is provided below. It installs the AD CS role, configures an Enterprise Root CA, and activates the CA Web Enrollment feature in a single operation. Using a script rather than the GUI wizard is standard practice in enterprise environments because it is repeatable, auditable, and can be version-controlled.

Question

Before running the script, predict: how many certificates will appear in the **Issued Certificates** node of the Certification Authority console immediately after the script completes? Give a reason.

1. (DC1) Right-click **Start**.
2. Select **Windows PowerShell (Admin)**.
3. Copy and run the following script:

```
# Install AD CS role and CA Web Enrollment feature
Install-WindowsFeature `
    -Name AD-Certificate, ADCS-Web-Enrollment, Web-Basic-Auth `
    -IncludeManagementTools

# Configure an Enterprise Root CA
Install-AdcsCertificationAuthority `
    -CAType EnterpriseRootCA `
    -CACommonName "contoso-DC1-CA" `
    -KeyLength 2048 `
    -HashAlgorithmName SHA256 `
    -ValidityPeriod Years `
    -ValidityPeriodUnits 5 `
    -Force
```

```
# Activate the CA Web Enrollment website (installs IIS as a
↪ dependency)
Install-AdcsWebEnrollment -Force

# Disable firewall default HTTP rule installed with IIS
Disable-NetFirewallRule IIS-WebServerRole-HTTP-In-TCP

# Fix the problem with incorrectly chosen firewall profile
Set-NetConnectionProfile -InterfaceAlias Ethernet -NetworkCategory
↪ Private
Disable-NetAdapter -InterfaceAlias Ethernet
Enable-NetAdapter -InterfaceAlias Ethernet
```

Expected result: Each cmdlet prints a result object (e.g. ErrorId: 0 - success). The entire script takes approximately 3–5 minutes.

4.3 Task 2 – Verify the CA and the Web Enrollment page

1. In **Server Manager**, click **Tools** → **Certification Authority**.
2. Expand the **contoso-DC1-CA** node.
3. Click **Issued Certificates**.

Expected result: Exactly one certificate is listed — the CA’s own self-signed certificate issued during setup. The CA certificate can appear 5 minutes after the setup.

4. By default, the CertSrv page requires SSL. For this lab we will disable this feature:
 1. Start Internet Information Services console
 2. Expand: DC1 → Sites → Default Web Site → CertSrv
 3. Open **SSL Settings**.
 4. Uncheck **RequireSSL** setting.
 5. Click **Apply** in the right pane.
5. Open **Microsoft Edge** on DC1.
6. Navigate to:

```
http://dc1.contoso.internal/certsrv
```

Expected result: The **Microsoft Active Directory Certificate Services** welcome page loads with the heading **Welcome** and links for requesting certificates.

If the page shows a 404 error, wait 30 seconds and refresh — IIS may still be finishing its configuration after the script.

4.4 Task 3 – Switch certsrv to Basic Authentication

By default, IIS authenticates users accessing **certsrv** using Windows Integrated Authentication (NTLM or Kerberos), which protects credentials inside an encrypted exchange.

To demonstrate the risk of cleartext HTTP in Exercise 3, you will switch the `certsrv` virtual application to Basic Authentication. Basic Authentication transmits credentials encoded in Base64 — encoding is not encryption, and any network observer can decode it instantly.

Question

Basic Authentication encodes credentials in Base64. What is the difference between encoding and encryption? Could an attacker who captures the Base64 value recover the original password without any special tools?

1. (DC1) In **Server Manager**, click **Tools** → **Internet Information Services (IIS) Manager**.
2. In the **Connections** pane, expand **DC1** → **Sites** → **Default Web Site**.
3. Click **CertSrv**.
4. In the centre pane, double-click **Authentication**.
5. Click **Windows Authentication**.
6. In the **Actions** pane on the right, click **Disable**.
7. Click **Basic Authentication**.
8. In the **Actions** pane, click **Enable**.
9. In the warning dialog that states credentials will be sent in cleartext, click **Yes**.

Expected result: **Windows Authentication** shows **Disabled** and **Basic Authentication** shows **Enabled**.

Sandbox note

Switching `certsrv` to Basic Authentication over HTTP is done here only to demonstrate credential exposure. In a production environment, `certsrv` must always use either Windows Integrated Authentication or HTTPS with a valid certificate. Never deploy Basic Authentication over plain HTTP in production — the credentials are visible to any observer on the network path.

4.5 Checkpoint

1. The script used `-CAType EnterpriseRootCA`. What would be different if you had used `StandaloneRootCA`? Name two functional differences relevant to this lab.
2. The CA issued itself exactly one certificate on startup. What is the purpose of this self-signed certificate, and why does every domain-joined machine trust it automatically without any manual configuration?
3. You disabled Windows Integrated Authentication on `certsrv`. Under Integrated Auth, would an attacker capturing the network traffic be able to recover the password? What does Wireshark show for an NTLM exchange compared to Basic Auth?

5 Exercise 2. Windows Firewall — Allow HTTP via Group Policy

5.1 Why this matters

A firewall rule created directly on a server is fragile: any local administrator can modify or delete it, and there is no central record of its existence. Deploying the same rule through Group Policy means the domain enforces it at every Group Policy refresh. The rule appears in `Get-NetFirewallRule` with `PolicyStoreSourceType : GroupPolicy`, making it auditable, consistent, and tamper-evident. The workflow in this exercise — create locally to test, verify, then migrate to a GPO — is the standard phased approach used when introducing firewall policy to a live environment where you cannot afford to lock yourself out.

5.2 Task 1 — Confirm that HTTP traffic from CL1 to DC1 is blocked

Question

Windows Firewall blocks all inbound traffic by default unless a rule explicitly permits it. Before testing, predict: will `Test-NetConnection` to TCP port 80 on DC1 succeed or fail from CL1? Give a reason based on the default firewall behaviour.

1. (CL1) Right-click **Start**.
2. Select **Windows PowerShell (Admin)**.
3. Run:

```
Test-NetConnection -ComputerName dc1.contoso.internal -Port 80
```

Expected result: The output shows `TcpTestSucceeded : False`. Port 80 is blocked.

5.3 Task 2 — Create a local inbound allow rule for TCP 80 on DC1

1. (DC1) Open **Windows PowerShell** as Administrator.
2. Run:

```
New-NetFirewallRule `
  -DisplayName "Allow HTTP Inbound" `
  -Direction Inbound `
  -Protocol TCP `
  -LocalPort 80 `
  -Action Allow `
  -Profile Domain
```

Expected result: The cmdlet prints a rule object with `Enabled : True`.

3. In **Server Manager**, open **Tools** → **Windows Defender Firewall with Advanced Security**.
4. Find the rule created in the Powershell.
5. (CL1) Re-run:

```
Test-NetConnection -ComputerName dc1.contoso.internal -Port 80
```

Expected result: **TcpTestSucceeded : True**. Port 80 is now reachable.

5.4 Task 3 – Authenticate to certsrv from CL1

1. (CL1) In Edge, navigate to:

```
http://dc1.contoso.internal/certsrv
```

2. In the login dialog, enter:

- **Username:** **contoso\administrator**
- **Password:** **P@ssw0rd**

3. Click **OK**.

Expected result: The **Microsoft Active Directory Certificate Services** welcome page loads. The page title shows the CA name **contoso-DC1-CA**.

Warning: Don't try to request a certificate - it requires Internet Explorer mode that is not installed at the moment.

5.5 Task 4 – Remove the local rule and replace it with a GPO-deployed rule

1. (DC1) Open **Windows PowerShell** as Administrator.
2. Remove the local rule:

```
Remove-NetFirewallRule -DisplayName "Allow HTTP Inbound"
```

3. (CL1) Confirm the port is blocked again:

```
Test-NetConnection -ComputerName dc1.contoso.internal -Port 80
```

Expected result: **TcpTestSucceeded : False**.

4. (DC1) In **Server Manager**, click **Tools** → **Group Policy Management**.
5. Expand **Forest: contoso.internal** → **Domains** → **contoso.internal**.
6. Expand **Domain Controllers**.
7. Right-click **Domain Controllers**.
8. Select **Create a GPO in this domain, and Link it here....**

9. In the **Name** field, type **FW-HTTP-DomainControllers**.
10. Click **OK**.
11. Right-click the new **FW-HTTP-DomainControllers** GPO.
12. Select **Edit**.
13. In the Group Policy Management Editor, navigate to:

```
Computer Configuration
→ Policies
→ Windows Settings
→ Security Settings
→ Windows Defender Firewall with Advanced Security
→ Inbound Rules
```

14. Right-click **Inbound Rules**.
15. Select **New Rule...**
16. On the **Rule Type** page, select **Port**.
17. Click **Next**.
18. On the **Protocol and Ports** page, confirm **TCP** is selected.
19. Select **Specific local ports** and type **80**.
20. Click **Next**.
21. On the **Action** page, select **Allow the connection**.
22. Click **Next**.
23. On the **Profile** page, check **Domain** only.
24. Uncheck **Private** and **Public**.
25. Click **Next**.
26. On the **Name** page, type **Allow HTTP Inbound GPO**.
27. Click **Finish**.
28. Close the Group Policy Management Editor.

5.6 Task 5 – Apply the GPO and verify the policy source

1. (DC1) Open **Windows PowerShell** as Administrator.
2. Force a Group Policy refresh:

```
gpupdate /force
```

Expected result: The output ends with **Computer Policy update has completed successfully**.

3. Verify the rule is active and came from the GPO:

```
Get-NetFirewallRule -PolicyStore ActiveStore -DisplayName "Allow
↪ HTTP Inbound GPO" |
  Select-Object DisplayName, Enabled, PolicyStoreSourceType
```

By default, `Get-NetFirewallRule` shows rules from the local store only. Specifying `-PolicyStore ActiveStore` includes rules from all sources, including Group Policy.

Expected result: `PolicyStoreSourceType` shows `GroupPolicy`. The rule exists because the GPO pushed it — not because a local administrator created it.

4. (CL1) Confirm connectivity is restored:

```
Test-NetConnection -ComputerName dc1.contoso.internal -Port 80
```

Expected result: `TcpTestSucceeded : True`.

5.7 Checkpoint

1. You linked the GPO to the **Domain Controllers** OU rather than to the root of the domain. Why is that the correct target for this rule? What would happen if you linked it to the domain root and DC1 were in a child OU?
2. `PolicyStoreSourceType` shows `GroupPolicy`. A local administrator later runs `New-NetFirewallRule` with identical settings but as a local rule. Which rule takes precedence, and how would you verify which one is controlling the port?
3. You used `-Profile Domain` when creating the rule. Would the rule still apply if DC1's network adapter reported the **Public** profile instead of **Domain**? What determines which profile is active on a domain controller?

6 Exercise 3. Capture Cleartext Credentials with Wireshark

6.1 Why this matters

Policy and architecture diagrams can describe what should be protected, but a packet capture shows what is actually on the wire. Seeing a domain administrator password appear in readable text in Wireshark makes the risk of cleartext protocols concrete in a way that no slide can. Every IT professional who deploys or audits web-based management interfaces — HR portals, monitoring dashboards, internal tools — should be able to run this check before going to production. The skill transfers directly to any HTTP service, not just `certsrv`.

In this exercise, `certsrv` is like a legacy software (similar to `telnet` or `ftp`), that does not support modern encryption like TLS or SSH, and must be protected with external methods, e.g. IPsec.

6.2 Task 1 — Install Wireshark on CL1

1. (CL1) Open a browser and navigate to:

<https://www.wireshark.org/download.html>

2. Download the **Windows x64 Installer**.
3. Run the installer and accept all defaults.
4. When the installer prompts to install **Npcap**, accept and install it.

Npcap is the packet capture driver that Wireshark uses to read traffic from the network adapter. Without it, live capture is not possible.

5. Complete the installation.
6. Do not launch Wireshark yet.

6.3 Task 2 — Start a capture and authenticate to certsrv

1. (CL1) Launch **Wireshark**.
2. In the **Capture** interface list, double-click the network adapter that shows traffic activity in its sparkline graph.

Wireshark starts capturing all packets immediately.

3. In the display filter bar at the top of the window, type:

http

4. Press **Enter** to apply the filter.

The filter hides all non-HTTP packets from the view, making the relevant traffic easier to find.

5. Open **Microsoft Edge** and navigate to:

<http://dc1.contoso.internal/certsrv>

6. In the login dialog, enter:

- **Username:** **contoso\administrator**
- **Password:** **P@ssw0rd**

7. Click **OK**.
8. Wait for the **certsrv** welcome page to finish loading.
9. Return to Wireshark.
10. Click the **Stop capturing packets** button (the red square icon in the toolbar).

6.4 Task 3 — Locate the credentials in the packet stream

1. In the Wireshark packet list, look for a row where the **Protocol** column shows **HTTP** and the **Info** column contains **GET /certsrv/**.
2. Click that row.
3. In the packet details pane below, expand the **Hypertext Transfer Protocol** section.
4. Expand the **Authorization** line.

Expected result: Wireshark shows a line similar to:

```
Authorization: Basic Y29udG9zb1xhZG1pbmlzdHJhdG9yOlBAC3N3MHJk\r\n
Credentials: contoso\\administrator:P@ssw0rd
```

Wireshark automatically decodes Base64 Basic Authentication credentials and displays them in plaintext under **Credentials**. The domain administrator password is visible to any observer with access to the network path.

Sandbox note

This exercise demonstrates why HTTP-only administrative interfaces must never be exposed on a production network — even on an internal LAN segment. An attacker with access to a network tap, a compromised switch SPAN port, or a man-in-the-middle position between CL1 and DC1 captures these credentials instantly. Exercise 4 addresses this by encrypting every IP packet between the two machines using IPsec, making the HTTP payload unreadable at the network level regardless of whether the application uses HTTPS.

6.5 Checkpoint

1. The credentials appeared in the HTTP **Authorization** header rather than in a form POST body. Does the location of the credentials within the HTTP message change the security risk in any way? Explain.
2. Would the same attack work if certsrv were still using Windows Integrated Authentication? What would Wireshark show in the Authorization header for an NTLM exchange instead?

7 Exercise 4. Protect HTTP Traffic with IPsec

7.1 Why this matters

IPsec operates at the IP layer, below all applications. Once configured, it encrypts every packet between two machines regardless of the application — HTTP, file shares, RDP, or anything else. When IPsec is active, the **certsrv** credentials visible in Exercise 3 become unreadable in Wireshark without any change to IIS or to Edge. This is the key architectural difference from HTTPS: IPsec covers all traffic between two endpoints simultaneously, not just one application. Tasks 1–3 of this exercise are a deliberate

controlled failure — you will configure IPsec with the wrong certificate and diagnose the most common real-world cause of silent IPsec breakage before fixing it and verifying the result.

7.2 Task 1 — Enroll a Computer certificate on DC1 and CL1

You will first attempt to use IPsec with the built-in **Computer** certificate template, which is available on every Enterprise CA by default.

1. (DC1) Press **Win + R**, type `certlm.msc`, press **Enter**.
2. In the console tree, expand **Personal**.
3. Right-click **Certificates** (under Personal).
4. Select **All Tasks** → **Request New Certificate**.
5. On the **Before You Begin** page, click **Next**.
6. On the **Select Certificate Enrollment Policy** page, click **Next**.
7. Check the box next to **Domain Controller** (on CL1 check **Computer** instead).
8. Click **Enroll**.
9. Click **Finish**.

Expected result: A certificate appears in **Personal** → **Certificates**. The **Issued By** column shows `contoso-DC1-CA`.

10. Repeat all steps above on **CL1**, logged in as `contoso\administrator`.

7.3 Task 2 — Configure Connection Security Rules on DC1 and CL1

1. (DC1) Press **Win + R**, type `wf.msc`, press **Enter**.
2. In the left pane, click **Connection Security Rules**.
3. In the **Actions** pane on the right, click **New Rule...**
4. On the **Rule Type** page, select **Server-to-server**.
5. Click **Next**.
6. On the **Endpoints** page, select **These IP addresses** and add `192.168.56.200` for Endpoint 1 and `192.168.56.101` for Endpoint 2.
7. Click **Next**.
8. On the **Requirements** page, select **Require authentication for inbound and outbound connections**.
9. Click **Next**.
10. On the **Authentication Method** page, click **Browse** next to CA name.
11. Click **OK** to accept provided CA certificate.
12. Click **Next**.
13. On the **Profile** page, leave all three profiles checked.
14. Click **Next**.
15. On the **Name** page, type `Require IPsec - Contoso`.
16. Click **Finish**.

17. Repeat all steps above on **CL1**.

Sandbox note

To avoid any risk of disconnection Remote Desktop, you are configuring the rule of type *Server-to-server* with both endpoints specified and with all profiles enabled. In production, you would typically configure a more restrictive rule, e.g. *Isolation* that applies to all connections and all addresses.

7.4 Task 3 – Verify the Security Association forms

1. (CL1) Generate traffic to DC1:

```
Test-NetConnection -ComputerName dc1.contoso.internal -Port 80
```

2. (DC1) Check for a Main Mode Security Association:

```
Get-NetIPsecMainModeSA
```

Expected result: One or more rows appear, listing both IP addresses and the certificate thumbprint used for authentication. A result here confirms that IKE Phase 1 (mutual authentication) succeeded.

3. Check for a Quick Mode Security Association:

```
Get-NetIPsecQuickModeSA
```

Expected result: One or more rows appear. A result here confirms that IKE Phase 2 succeeded and an encrypted channel is active between DC1 and CL1.

Sandbox note

Use PowerShell cmdlets to check for Security Associations, because the console Windows Defender Firewall with Advanced Security sometimes does not show the Main Mode associations.

7.5 Task 4 – Confirm traffic is encrypted with Wireshark

1. (CL1) Launch **Wireshark** and start a new capture on the same adapter as before.
2. In the display filter bar, type:

```
esp
```

3. Press **Enter** to apply the filter.
4. In **Edge**, navigate to:

```
http://dc1.contoso.internal/certsrv
```

5. In the login dialog, enter the same credentials as before and click **OK**.
6. Wait for the **certsrv** welcome page to load.

7. Return to Wireshark and stop the capture.

Expected result: The captured packets show **ESP** (Encapsulating Security Payload) protocol. The entire HTTP exchange — including the Authorization header and credentials — is encrypted inside the ESP payload. No packet content is readable.

8. Change the display filter to **http** and press **Enter**.

Expected result: No packets appear. The HTTP traffic is encapsulated inside ESP and is invisible to any application-layer filter.

7.6 Checkpoint

1. In this lab you used **Require authentication** mode from the start. In production, why is it recommended to begin with **Request authentication**, verify all machines form SAs, and only then switch to Require?

8 Summary

In this lab you built a complete network security stack starting from a domain with no PKI and no enforced firewall policy. You installed a CA with a PowerShell script, exposed a real administrative credential in Wireshark, enforced a firewall rule through Group Policy, and encrypted the same channel with IPsec — confirming with a second Wireshark capture that the payload was no longer readable.

Discuss at home: In this lab you protected HTTP traffic using IPsec at the network layer. An alternative fix is to configure IIS to serve **certsrv** over HTTPS (port 443) using the CA certificate you deployed — which encrypts at the application layer (as you did in the previous lab). Compare the two approaches: which protects more traffic between DC1 and CL1? Which is easier to extend to additional services? In a real hardening engagement, under what circumstances would you choose application-layer HTTPS over network-layer IPsec, and when would you deploy both?